

北京邮电大学

《信息系统安全》



第一次作业

学 号： 2022211570

姓 名： 项 枫

班 级： 2022211801

专 业： 信息安全

学 院： 网络空间安全学院

2024 年 11 月 10 日

目 录

一、信息系统设计	1
(一) 应用场景设计	1
(二) 安全威胁分析	2
二、安全需求分析	4
三、安全策略制定	6
四、安全风险评估	7
五、等级保护定级	11
(一) 定级报告	11
(二) 备案申请	11

一、信息系统设计

(一) 应用场景设计

设计一个**在线教育平台**，该平台主要用于学生注册、参加课程、下载课程资料、提交作业和在线考试。系统包括以下模块：

1、用户管理模块：允许学生和教师进行注册、更新个人资料，管理员进行权限管理。

2、课程管理模块：教师可以创建课程并可以上传和管理课程内容，学生可以加入课程并可以下载课程内容，包括课程讲义、视频和作业等；教师可以开启线上直播，学生可以进入线上课堂听课，并可以实时提问、讨论等。

3、作业和考试模块：教师在线发布作业，学生在线提交作业，教师可以在线批改并进行成绩评判，批改结束后，学生可查看作业批改情况和成绩；教师在线开启考试，学生进入考试系统进行作答，考试结束后，教师进行批改和成绩评定，批改结束后，学生可查看试卷作答情况和成绩。

4、成绩管理模块：教师对课程内每位学生进行成绩登录，登录完毕后，学生可查看课程所得分数。

5、消息通知模块：同一课程内的用户之间可以私聊对话，教师可向班级内的同学发送课程相关通知。此外，系统可向所有用户发送版本更新、系统维护等通知。

6、学习进度跟踪模块：系统提供学习进度追踪功能，记录学生在每个课程中的学习状态，如已观看的视频时长、完成的作业数和测验分数等。学生和教

师可以随时查看学习进度，帮助学生合理安排学习计划，教师也可以依据进度调整教学内容，以更好地满足学生的学习需求。

7、数据分析与报告模块：系统内置数据分析功能，可以生成有关学生学习表现的多维度报告，包括平均成绩、考试通过率、参与度等，为教师提供数据支持，以便优化课程内容。同时，学生也可以查看个人学习数据，如学习时间、成绩进步曲线等，以便及时调整学习策略。

(二) 安全威胁分析

1、物理环境安全威胁

设备损坏：如火灾、水灾、地震等自然灾害和电力系统破坏可能损坏服务器、存储设备等，导致数据丢失或系统中断。

设备盗窃：未经授权的人员可能进入机房或办公室，窃取硬件设备或存储介质，造成数据泄露。

恶意破坏：攻击者或内部的恶意人员可能破坏服务器或设备，导致系统不可用。

2、通信链路安全威胁

窃听：在数据传输中，攻击者可能通过窃听通信链路获取敏感数据（如用户信息、课程内容等）。

中间人攻击：攻击者可能在数据传输链路中截取和篡改数据包，导致数据被篡改或泄露。

3、网络系统安全威胁

拒绝服务攻击 (DoS/DDoS): 攻击者可能发起大规模的访问请求, 导致网络带宽耗尽, 服务器崩溃, 用户无法正常访问。

网络入侵: 攻击者可能利用弱口令或网络漏洞入侵服务器, 获取控制权。

网络设备漏洞: 路由器、交换机等设备若未及时更新补丁, 可能存在漏洞, 成为攻击入口。

4、操作系统安全威胁

系统漏洞: 操作系统存在的安全漏洞可能被攻击者利用, 导致非法访问、权限提升或恶意程序植入。

恶意软件: 操作系统若未开启防护机制, 可能会感染病毒、木马等恶意软件, 进而导致数据泄露或系统失效。

权限滥用: 未授权的用户可能通过操作系统接口访问敏感信息, 或对数据进行篡改。

5、应用系统安全威胁

身份冒充: 攻击者可能利用账号漏洞或凭证窃取冒充合法用户, 上传、篡改、下载课程相关内容。

SQL 注入和 XSS 攻击: 攻击者通过输入恶意代码, 可能注入数据库或在网页上执行恶意脚本, 从而获取敏感信息或劫持用户会话。

跨站请求伪造（CSRF）威胁：攻击者诱导用户在已登录的情况下执行恶意操作。

API 接口未授权访问：如果 API 接口未保护，攻击者可以直接调用接口，获取敏感信息或执行操作。

数据泄露：由于设计不完善，应用系统中的敏感信息（如用户个人信息、课程内容等）可能被泄露或被篡改。

系统崩溃：高并发的课程直播或考试流量可能导致应用系统崩溃或响应缓慢，影响用户体验。

6、管理系统安全威胁

权限滥用：系统管理员或开发人员若拥有过高权限，可能在操作中对数据进行不当处理或篡改。

配置不当：错误配置可能导致系统开放了不必要的端口或功能，成为攻击入口。

缺乏审计和监控：若缺乏日志记录和监控，系统中的安全事件（如未授权访问、异常登录等）将无法及时发现。

内部威胁：系统内部人员（如管理员或开发者）可能会滥用系统权限，造成数据泄露或损害。

二、安全需求分析

目标：确保在线教育平台的整体安全，保护用户数据、课程内容和平台运行稳定性。

1、用户身份验证需求

需求描述：确保每位用户（学生、教师和管理员）的身份都能被有效地识别和验证。

实现方式：使用多因素身份验证（如密码、短信验证码或生物识别）和角色权限控制。

安全性保障：避免非授权用户访问平台，保护课程内容和用户隐私。

2、信息完整性需求

需求描述：确保平台内的信息在传输和存储过程中不会被篡改、损坏或丢失。

实现方式：使用数据加密传输、校验码和哈希算法来检测数据的完整性。

安全性保障：保持学生的学习记录、课程资料和作业成绩的准确性。

3、信息不可伪造性需求

需求描述：确保平台上每项操作的真实性，不允许伪造任何数据。

实现方式：通过数字签名、访问日志记录等手段保障信息的真实性。

安全性保障：防止用户伪造身份信息、伪造作业提交记录等，确保操作的可信性。

4、信息不可抵赖性需求

需求描述：确保用户在平台上进行的每一项操作（如提交作业、考试答题）都具备不可抵赖的证据。

实现方式：通过日志记录和数字签名技术保存用户的操作记录，确保记录不可篡改。

安全性保障：确保用户无法否认自身在平台上进行的操作，增强平台的可信度。

三、安全策略制定

访问控制矩阵：

操作 \ 用户	学生	教师	管理员
注册/登录	可以注册、登录	可以注册、登录	可以注册、登录
个人资料管理	查看和更新个人资料	查看和更新个人资料	查看和更新所有用户资料
课程管理	加入课程、查看课程	创建、修改、删除课程	查看所有课程
上传课程内容	无权限	上传讲义、视频、作业	无权限
下载课程资料	下载课程资料	查看、下载课程资料	查看、下载所有课程资料
作业管理	提交作业	发布作业、批改作业	查看所有作业
考试管理	参加考试	发布考试、批改试卷	查看所有考试
成绩管理	查看自己的成绩	录入、修改学生成绩	查看所有成绩
课程直播	观看直播、提问	开启直播、管理课堂	无权限
消息通知	查看课程通知、私聊	向学生发送通知、私聊	向所有用户发送通知
学习进度跟踪	查看自己的进度	查看学生的进度	查看所有学生进度

数据分析与报告	查看自己的学习报告	查看自己的学生报告	查看所有学生数据报告
---------	-----------	-----------	------------

四、安全风险评估

1、资产识别与评估

(1) 资产识别。在线教育系统的核心资产包括以下几类：

数据资产：包括用户的个人信息、学习记录、考试成绩、课程内容、支付信息等。

软件资产：在线教育平台的应用软件、数据库管理系统和操作系统等。

硬件资产：包括服务器、路由器、交换机和防火墙等设备。

网络服务：提供平台访问的网络基础设施。

业务服务：为用户提供的课程内容管理、学习活动管理、测试和反馈等核心业务功能。

(2) 资产赋值。资产的重要性可以通过保密性、完整性和可用性需求进行赋值。例如：

保密性赋值：用户的个人信息和支付信息需要较高的保密性。

完整性赋值：学习记录、成绩等数据需要保持一致性，不能被随意篡改。

可用性赋值：系统的可用性对用户体验至关重要，特别是在课程进行和考试期间，系统必须高效运行。

2、威胁识别与分析

(1) 威胁识别。在线教育系统威胁来源包括以下几种：

环境因素：如停电、设备故障等，可能影响平台的运行。

人为因素：包括内部员工的误操作或恶意行为（例如，未经授权修改数据），以及外部黑客攻击。

恶意攻击：例如 SQL 注入、DDoS 攻击、恶意软件攻击、跨站脚本 (XSS) 和跨站请求伪造 (CSRF) 等。

自然灾害：如火灾、洪水、地震等，可能会造成物理设备损坏和数据丢失。

(2) 威胁分析。每种威胁的影响程度可以通过威胁的出现频率和影响范围来评估。比如：

DDoS 攻击：攻击频率较高且容易影响系统的可用性。

SQL 注入和 XSS 攻击：这些威胁可能影响数据的完整性和机密性。

人为误操作：内部人员的误操作可能导致数据丢失或错误。

3、脆弱性识别与赋值

(1) 脆弱性识别。在线教育系统可能存在以下脆弱性：

代码漏洞：应用程序代码缺乏输入验证和错误处理，容易受到 SQL 注入和 XSS 攻击。

不安全的接口：API 接口缺乏认证和加密保护，可能被未经授权访问。

弱密码：用户和管理员账户的密码复杂度不足，增加被破解的风险。

配置错误：例如数据库或服务器的安全配置不足，可能被外部攻击者利用。

缺乏日志和监控：没有适当的日志记录和监控，难以及时发现和应对安全事件。

(2) 脆弱性赋值。每个脆弱性可以赋值其严重程度。对于在线教育系统来说：

高严重性脆弱性：如代码中的 SQL 注入漏洞、不安全的接口。

中等严重性脆弱性：如用户和管理员的弱密码。

低严重性脆弱性：如部分数据缺乏日志记录。

4、风险计算与分析

风险值 = $R(A, T, V) = R(L(T, V), F(Ia, Va))$ 。

5、风险应对策略

根据风险评估结果，可采取以下风险应对策略：

降低风险：对系统中的脆弱性采取控制措施，例如代码审计和测试以减少 SQL 注入漏洞，启用强密码策略以减少账户被破解的风险，部署 DDoS 防护系统以减少拒绝服务攻击的影响。

转移风险：通过购买网络安全保险，将部分风险转移给第三方。

避免风险：尽量避免存储过多敏感信息，减少数据泄露的风险。

接受风险：对于一些低影响的残留风险，可以选择接受，例如内部低权限用户的误操作风险，考虑到成本与效益，可能无需特别处理。

6、残留风险监控

在实施安全控制措施之后，仍然可能存在一定的残留风险。这些残留风险需要进行监控和定期评估，以确保在新的威胁环境下系统的安全性。残留风险的控制策略包括：

定期漏洞扫描和渗透测试：定期检查系统的安全性，识别新的脆弱性和风险。

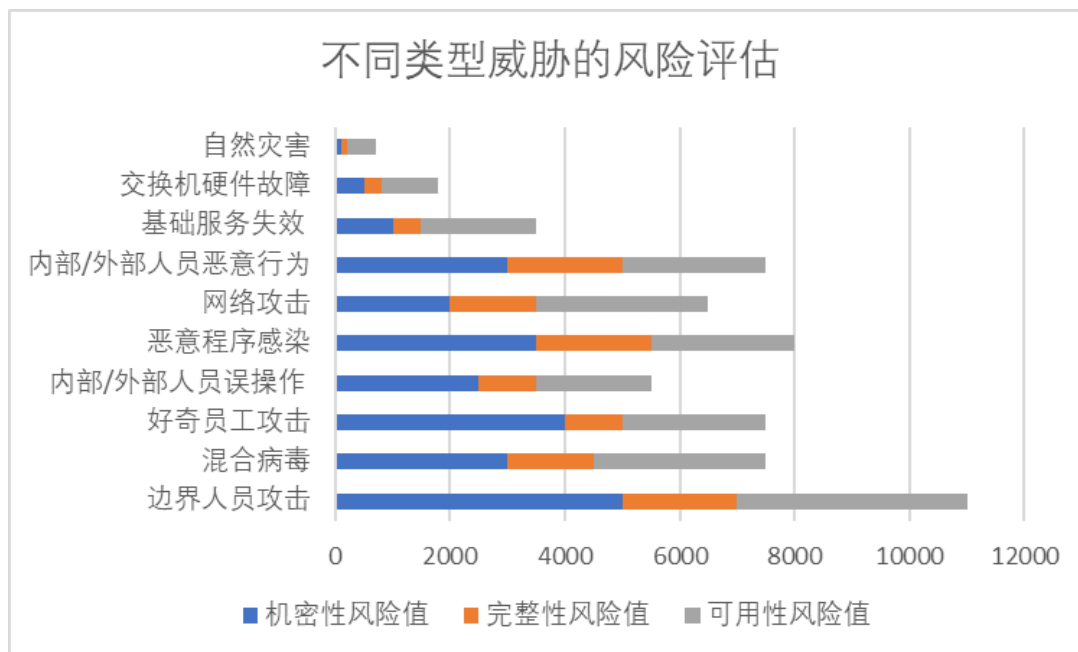
日志监控和审计：监控系统日志以发现异常行为，并定期审计用户的操作记录。

安全教育和培训：提高内部人员的安全意识，减少人为误操作的风险。

7、风险评价：

威胁类型	机密性风险值	完整性风险值	可用性风险值
边界人员攻击	5000	2000	4000
混合病毒	3000	1500	3000
好奇员工攻击	4000	1000	2500
内部/外部人员误操作	2500	1000	2000
恶意程序感染	3500	2000	2500
网络攻击	2000	1500	3000
内部/外部人员恶意行为	3000	2000	2500
基础服务失效	1000	500	2000

交换机硬件故障	500	300	1000
自然灾害	100	100	500



五、等级保护定级

(一) 定级报告

根据《信息安全技术 网络安全等级保护基本要求》(GB/T 22239-2019), 当信息系统受到破坏后, 会对公民, 法人和其他组织的合法权益产生严重损害, 或者对社会秩序和公共利益造成损害, 但不损害国家安全。所以该系统定为二级。

(二) 备案申请

根据《信息安全技术 网络安全等级保护基本要求》(GB/T 22239-2019) 等相关法律法规, 该系统在上线之前需要进行备案申请。具体步骤如下:

1、确定安全等级:

本平台确定为二级安全保护。

2、准备材料：

《定级报告》、《信息系统安全等级保护备案表》及光盘。

3、提交备案：

向地市级以上公安机关网络安全保卫部门提交备案申请，经过审核后获得备案批准。